ПРАКТИЧЕСКОЕ ЗАНЯТИЕ № 2

АНАЛИЗ РИСКОВ

Вариант А. Сервер интернет-магазина

Шаг 1. Описание системы

Рассматриваемая система — сервер интернет-магазина, который продаёт бытовую электронику. Он обеспечивает работу сайта: показ каталога товаров, приём и обработку заказов, онлайн-оплату, а также хранение базы данных клиентов и заказов. Пользователями системы являются покупатели, менеджеры по продажам, администраторы сервера и сотрудники службы поддержки. Критичными функциями считаются оформление и оплата заказов, сохранность данных клиентов и непрерывная доступность сайта. Сервер работает круглосуточно в арендованном центре обработки данных и испытывает повышенную нагрузку в период распродаж. Условия эксплуатации включают постоянное подключение к интернету, угрозу внешних атак и необходимость соблюдать требования закона о защите персональных данных.

Шаг 2. Идентификация рисков

Таблица 1 — Идентификация рисков

ID	Описание риска	Объект уязвимости	Угроза
R-01	Выход из строя жёсткого диска или SSD сервера, на котором хранится база данных заказов и клиентов	Аппаратный (накопитель данных)	Отказ
R-02	DDoS-атака: сайт перегружается потоком запросов и становится недоступным для покупателей	Программный (веб-сервер, сетевой канал)	Блокирование
R-03	SQL-инъекция через уязвимую форму сайта и кража персональных данных клиентов	Программный (веб-приложение)	Утечка
R-04	Ошибка администратора при обновлении ПО или изменении настроек сервера	Человеческий (администратор)	Ошибка
R-05	Отключение электропитания в центре обработки данных	Аппаратный (система электропитания)	Отказ

ID	Описание риска	Объект уязвимости	Угроза
R-06	Кража данных банковских карт покупателей, если они хранятся на собственном сервере	Информационный (платёжные данные)	Утечка
R-07	Заражение сервера вирусом-шифровальщиком, файлы базы данных становятся недоступными	Программный (операционная система)	Потеря целостности
R-08	Повреждение или потеря резервных копий базы данных	Информационный (резервные копии)	Потеря целостности
R-09	Перегрузка сервера в период распродаж: сайт работает медленно или «зависает»	Аппаратный (процессор, память)	Сбой
R-10	Истечение срока действия SSL-сертификата: браузеры блокируют вход на сайт	Программный (настройки веб-сервера)	Блокирование

Шаг 3. Оценка рисков и меры снижения

Таблица 2 — Оценка рисков и меры

ID	Риск	Вероятность (1–5) и обоснование	Тяжесть (1–5) и обоснование	Уровень	Зона	Мера снижения	Стратегия	Ожидаемый эффект
R-01	Отказ накопителя	**3.** Накопители изнашиваются, за срок службы отказ вполне возможен.	**5.** Возможна потеря базы заказов и клиентов.	15	Высокий	Техническая: массив RAID 10, контроль состояния дисков (SMART), репликация базы данных на второй сервер.	Снижение	Отказ одного диска не приводит к потере данных и простою.
R-02	DDoS-атака	**4.** Интернет-магазины часто подвергаются таким атакам, в том числе со стороны конкурентов.	**4.** Простой сайта ведёт к потере продаж и репутации.	16	Критический	Техническая: подключить защиту от DDoS у провайдера или CDN, настроить ограничение числа запросов.	Передача	Основная часть вредного трафика отсекается до сервера.
R-03	SQL-инъекция	**3.** Уязвимости веб-приложений встречаются часто, а сайт доступен всем.	**5.** Утечка персональных данных влечёт штрафы и потерю доверия клиентов.	15	Высокий	Программная: параметризованные запросы, межсетевой экран веб-приложений (WAF), регулярная проверка кода на уязвимости.	Снижение	Вероятность успешной атаки существенно снижается.
R-04	Ошибка администратора	**3.** Обновления проводятся регулярно, и ошибки при этом случаются.	**4.** Неверная настройка может остановить магазин на несколько часов.	12	Высокий	Организационная: регламент обновлений, проверка на тестовом стенде, обязательная копия настроек перед изменением.	Снижение	Ошибки выявляются до запуска в работу, откат занимает минуты.
R-05	Отключение питания	**2.** В центрах обработки данных есть резервное питание, сбои бывают редко.	**4.** Внезапное отключение может повредить данные и остановить продажи.	8	Средний	Техническая: установить ИБП, выбрать дата-центр с резервным вводом питания и дизель-генератором.	Снижение	Сервер продолжает работу при кратковременных сбоях питания.

ID	Риск	Вероятность (1–5) и обоснование	Тяжесть (1–5) и обоснование	Уровень	Зона	Мера снижения	Стратегия	Ожидаемый эффект
R-06	Компрометация данных карт	**2.** Для атаки нужен доступ к хранилищу, но интерес злоумышленников к таким данным высок.	**5.** Ущерб покупателям, штрафы платёжных систем, юридические последствия.	10	Высокий	Организационная: не хранить данные карт на своём сервере, принимать оплату через сертифицированного платёжного провайдера.	Избежание	Риск исключается, так как данных карт на сервере нет.
R-07	Вирус-шифровальщик	**2.** Антивирус и межсетевой экран есть, но такие атаки распространены.	**5.** Данные недоступны, их восстановление может оказаться невозможным.	10	Высокий	Программная: антивирус, своевременные обновления ОС, ограничение прав пользователей, отключение лишних сетевых служб.	Снижение	Вероятность заражения снижается, ущерб ограничивается.
R-08	Потеря резервных копий	**2.** Копии создаются автоматически, но возможны сбои носителей и ошибки настройки.	**4.** При отказе основных данных восстановить их будет нечем.	8	Средний	Организационная: хранение копий по правилу 3-2-1, ежемесячная проверка восстановления из копии.	Снижение	Подтверждённая возможность восстановления данных.
R-09	Перегрузка при распродаже	**4.** Распродажи проходят несколько раз в год, нагрузка растёт многократно.	**3.** Замедление ведёт к потере части заказов, но данные сохраняются.	12	Высокий	Техническая: кеширование страниц, балансировка нагрузки, временное увеличение мощности, нагрузочное тестирование перед акцией.	Снижение	Сайт выдерживает пиковую нагрузку без замедления.
R-10	Истечение SSL-сертификата	**2.** Срок известен заранее, ошибка возможна только по забывчивости.	**2.** Проблема устраняется быстро, потери времени небольшие.	4	Низкий	Организационная: напоминание администратору за 30 дней до окончания срока действия сертификата.	Принятие	Риск остаётся низким, затраты на автоматизацию не оправданы.

Шаг 4. Остаточный риск

Для анализа выбраны три риска с наибольшим уровнем: R-02 (16 баллов), R-01 (15 баллов) и R-03 (15 баллов).

Таблица 3 — Остаточный риск

ID	Риск	Исходный уровень	Внедрённые меры	Новый уровень	Остаточный риск приемлем?
R-02	DDoS-атака	16 (критический)	Защита от DDoS у провайдера или CDN, ограничение числа запросов	8 (средний): вероятность 2, тяжесть 4	Да, риск остаётся под контролем
R-01	Отказ накопителя	15 (высокий)	RAID 10, контроль состояния дисков, репликация базы данных	6 (средний): вероятность 2, тяжесть 3	Да
R-03	SQL-инъекция	15 (высокий)	Параметризованные запросы, WAF, регулярная проверка кода	8 (средний): вероятность 2, тяжесть 4	Да, при регулярных проверках безопасности

Шаг 5. Вывод

Самыми опасными оказались DDoS-атака (16 баллов), отказ накопителя сервера и SQL-инъекция (по 15 баллов). Они получили высокие оценки, потому что их последствия затрагивают главное: доступность сайта и сохранность данных клиентов, а вероятность таких событий для интернет-магазина немалая. После внедрения мер уровни этих рисков удалось снизить до 8, 6 и 8 баллов, то есть до среднего уровня, который можно контролировать. Остаточные риски признаны приемлемыми, однако риск утечки данных через уязвимости сайта допустим только при регулярных проверках безопасности. Дополнительного внимания требуют проверка восстановления из резервных копий, своевременное обновление программного обеспечения и нагрузочное тестирование перед распродажами. Оценки рисков следует периодически пересматривать, так как угрозы и условия работы магазина меняются.